

OFFSEC

UNDERWORLD



1

SUMÁRIO

1 UNDERWORLD	3
1.1 Orientações iniciais	3
1.2 Explorando segredos	4
2 NAS SOMBRAS	7

EMSE

1 UNDERWORLD

1.1 Orientações iniciais

Olá! Seja muito bem-vindo(a) à terceira fase do segundo ano letivo do curso superior em Defesa Cibernética do FIAP ON! Nesta fase, os alunos irão explorar a mentalidade de um hacker e cada etapa de um processo de pentest.

Ao adentrarmos o domínio da segurança cibernética, nos deparamos com um universo vasto e desafiador, cuja complexidade e importância só têm crescido no contexto atual. A constante evolução tecnológica, acompanhada pela expansão acelerada do espaço digital, não apenas tem ampliado as fronteiras da inovação e da conectividade, mas também tem elevado significativamente os riscos associados à segurança de informações e sistemas. Este cenário tem demandado uma atenção especial para o desenvolvimento de estratégias defensivas robustas, dentre as quais o *Penetration Testing* (Pentest) se destaca como uma prática fundamental.

O Pentest, ou teste de penetração, emerge como uma metodologia essencial no arsenal de defesa cibernética, atuando como uma imitação de ataques contra sistemas para identificar vulnerabilidades antes que sejam exploradas por agentes mal-intencionados. Com um enfoque prático e ofensivo, esta prática permite uma avaliação crítica das medidas de segurança em vigor, revelando pontos de fragilidade em infraestruturas digitais complexas. Através de um processo meticuloso que envolve etapas como coleta de informações, enumeração, quebra de senhas, análise de vulnerabilidade e exploração, os especialistas em Pentest fornecem *insights* valiosos para o fortalecimento de sistemas contra intrusões indesejadas.

Em uma era marcada pela digitalização sem precedentes, as estatísticas sobre ciberataques e suas consequências destacam a urgente necessidade de tais avaliações. Por exemplo, relatórios recentes indicam um aumento expressivo no número e na sofisticação de ataques cibernéticos. Um estudo conduzido pela *Cybersecurity Ventures* prevê que os custos globais do cibercrime às organizações de todo o globo crescerão 15% ao ano, atingindo US\$ 10,5 trilhões anualmente até 2025, um reflexo direto da crescente ameaça que tais atividades representam para organizações de todos os tamanhos e setores. Ademais, o advento de técnicas

avançadas de ataque, como o *Buffer Overflow* e exploração de vulnerabilidades específicas, reforça a importância de uma preparação adequada e da adoção de práticas de segurança cibernética evolutivas.

Portanto, à medida que navegamos pelos capítulos que se seguem, explorando desde os fundamentos do *mindset hacker* até os desafios impostos pela ciberguerra e pelo ciberterrorismo, é crucial reconhecermos a segurança cibernética não apenas como um campo de estudo técnico, mas como um elemento vital na preservação da integridade, confidencialidade e disponibilidade das nossas infraestruturas digitais. Aprofundar-se no conhecimento e na aplicação prática das técnicas discutidas é um passo indispensável para quem deseja contribuir ativamente na construção de um ambiente digital mais seguro e resiliente.

1.2 Explorando segredos

É hora de revelar um resumo do que você verá nessa fase:

- **Cap 2 - Pentest:** Aqui aprofundaremos os tópicos sobre *Pentesting*! Exploraremos a fundação do *Penetration Test*, passando pelas etapas cruciais e a importância da comunicação eficaz no processo, incluindo a cadeia de comando e a interação com o cliente. Além disso, veremos detalhes essenciais sobre contratos, escopos variados de teste e a preparação técnica necessária.
- **Cap 3 - Captura de Informações:** Mergulharemos no processo essencial de coleta de informações em testes de penetração, destacando sua ampla abrangência, desde a identificação de inteligência acionável até o uso de *Open Source Intelligence* (OSINT) para a coleta discreta de dados nas fases iniciais.
- **Cap 4 - Enumeração:** Exploraremos a fase de enumeração em testes de penetração, como o uso de técnicas detalhadas de varredura de portas com Nmap, conceituação, métodos (incluindo *banner grabbing*) e especificidades de uma enumeração em ambientes Windows, Linux e web.
- **Cap 5 - Análise de Vulnerabilidade:** Aqui aprenderemos sobre as

principais técnicas de varredura e análise de vulnerabilidade, entendendo o que é uma CVE, quais são suas prioridades e como categorizá-las. Além disso, veremos também os vários tipos de análise de vulnerabilidades e utilizaremos o OpenVas para analisá-las.

- **Cap 6 - Exploração:** Iremos falar sobre exploração, desde o mapeamento de vulnerabilidades até técnicas de ataque, incluindo decepção e engenharia social. Avançaremos para ataques em redes e o uso de *exploits*, finalizando com uma introdução ao *Metasploit*.
- **Cap 7 - Pós-exploração:** Aprenderemos sobre as principais técnicas de pós-exploração, com as características dos sistemas operacionais Windows e Linux, escalação de privilégios, permissionamento de arquivos e identificação de serviços.
- **Cap 8 - Pentest Report:** Aprenderemos sobre a elaboração de relatórios de pentest, abordando o que incluir, desde a coleta de informações ao desenvolvimento e revisão do relatório.
- **Cap 9 - Ciberguerra e Ciberterrorismo:** Ciberguerra e ciberterrorismo são preocupações presentes em nações que precisam estar atentas aos sinais de potenciais conflitos oriundos de meios de comunicação e sistemas eletrônicos. Conhecer a anatomia dessas ameaças é essencial ao profissional que atua em cibersegurança.
- **Cap 10 – Segurança em Infraestruturas Críticas:** Abordaremos a importância da proteção das infraestruturas críticas para garantir a continuidade de serviços essenciais à sociedade. Apresentaremos ameaças, vulnerabilidades e medidas de segurança cibernética e física, além de discutir a necessidade de políticas integradas e cooperação entre setores público e privado.
- **Cap 11 - Offensive Mindset:** Hora de falarmos sobre a mentalidade ofensiva e Pentest! Abordaremos conceitos básicos, pilares da segurança, tipos e modalidades de testes e as etapas detalhadas do Pentest.
- **Cap 12 - Quebra de Senhas:** Iremos comentar sobre criptografia e funções *hashing*. Além disso, detalharemos a segurança de senhas em Windows e

Linux, destacando técnicas e ferramentas específicas, incluindo ataques *Pass-the-Hash* e uso de *WordLists* e *Rainbow Tables*. Também abordaremos ferramentas de quebra de senha como *Hydra* e *Hashcat*, finalizando com um mergulho no *Metasploit Framework* e práticas laboratoriais.

- **Cap 13 - Framework Metaexploit:** Iremos navegar pelo *Framework Metaexploit*, começando com seus módulos auxiliares, ataques de força bruta e técnicas de levantamento de informações. Avançaremos explorando vulnerabilidades específicas em sistemas Linux e Windows, culminando na utilização do *Meterpreter* para controle pós-exploração.
- **Cap 14 - Python for Red Team:** Faremos uma revisão sobre a linguagem Python do ponto de vista de um desenvolvedor de *exploit*, cobrindo desde fundamentos como operações matemáticas e estruturas condicionais, até programação avançada com sockets e manipulação de dados em *Big Endian* e *Little Endian*.
- **Cap 15 - Buffer Overflow Clássico:** Exploraremos o conceito e a execução do *Buffer Overflow*, detalhando os passos para a criação de um *exploit*, desde a conexão com a aplicação até a geração de *shellcode*, passando por técnicas como *fuzzing*, manipulação de endereço de retorno e controle do fluxo de execução.
- **Cap 16 - Buffer Overflow SEH:** Abordaremos o *Buffer Overflow SEH*, explicando o que é o SEH e detalhando as fases para explorá-lo: conectar na aplicação, realizar o *fuzzing*, sobrescrever o ponteiro de SEH, encontrar a sequência POP/POP/RET, realizar JMP SHORT, saltar para um *buffer* maior, verificar caracteres inválidos e gerar *shellcode*.
- **Cap 17 - Buffer Overflow Egghunter:** O que acontece se a aplicação tiver proteções para evitar esses ataques de *Buffer Overflow*? Neste capítulo, exploraremos o *exploit* de *egghunter*, desde o seu funcionamento até a criação prática de um *egghunter*, abrangendo a introdução e desenvolvimento desse método para localizar *payloads* em memória.
- **Cap 18 - Pós-exploração Windows:** Iremos entender como utilizar técnicas para obter vantagem de sistemas Windows na visão de um

atacante que já possui acesso a uma ou mais máquinas a partir de um usuário não privilegiado.

- **Cap 19 - Pós-exploração Linux I:** Estudaremos a pós-exploração em Linux, cobrindo a preparação do ambiente, uso de *shells*, transferência de arquivos e um levantamento completo de informações do host, focando em identificar sistema operacional, *kernel*, serviços, permissões e potenciais vulnerabilidades para escalonamento de privilégios.
- **Cap 20 - Pós-exploração Linux II:** Daremos continuidade ao tema de pós-exploração em Linux, destacando processos automatizados, como o uso de *Linpeas* para reconhecimento, estratégias de escalonamento de privilégios envolvendo “sudo”, permissões, “cron” e exploração de vulnerabilidades no kernel. Abordaremos também técnicas de *pivoting* para explorar redes mais amplas, além de métodos e ferramentas essenciais.

2 NAS SOMBRAS

E chegamos a mais uma etapa da sua jornada cibernética. Será que você conseguirá se ocultar das dificuldades que o caminho hacker proporciona até chegar ao conhecimento que almeja? Mergulhe ao máximo nesse mundo profundo e bons estudos!